Informe de auditoría de SIGAA

Revisión de código, seguridad y preparación para producción — noviembre de 2026

Alcance: servidor (API, base de datos, PDF/Excel, importaciones), aplicación web, versión de escritorio, instaladores y dependencias.

Resultado: se encontraron y **corrigieron 10 problemas** (1 crítica y 3 de gravedad alta). Quedan riesgos menores documentados y una lista de verificación para entrar en producción.

Verificación: 206 pruebas automáticas pasan con SQLite y 205 con **PostgreSQL 16** (las demás se omiten por diseño); revisión de tipos y compilación sin errores.

1. Cómo se auditó

- **Dependencias:** análisis de vulnerabilidades conocidas (`npm audit`) de todo lo que viaja a producción.
- **Código:** revisión de rutas y permisos, consultas SQL, manejo de archivos, fechas, numeración de documentos y concurrencia.
- **Seguridad:** inicio de sesión, sesiones, subida de archivos, cabeceras, registro (log) y versión de escritorio.
- **Pruebas:** toda la suite con **SQLite** y con **PostgreSQL**; reproducción de cada falla antes de corregirla y prueba nueva para que no vuelva.
- **Pantallas:** recorrido en navegador de las pantallas nuevas (logo, importaciones, producción, etiquetas, vales).

2. Problemas encontrados y corregidos

N.º	Gravedad	Qué se encontró	Cómo se corrigió
1	**CRÍTICA**	Componente de sesiones (`@fastify/jwt` / `fast-jwt`) con fallas conocidas: confusión de algoritmo y cabeceras no válidas aceptadas en las sesiones.	Actualizado a la versión corregida (v10). Prueba de inicio de sesión y permisos repetida.
2	**ALTA**	Servidor de archivos (`@fastify/static`) con vulnerabilidad de recorrido de rutas y salto de restricciones.	Actualizado (v10). También `fastify` 5.12.8, `react-router` 7 y `fast-uri`: de **11 vulnerabilidades (2 críticas, 1 alta)** a **2 moderadas** sin riesgo real (ver punto 4.1).
3	**ALTA**	Subida de fotografías: el número de foto venía de la dirección sin validar, de modo que un usuario con permiso de Activos Fijos podía **escribir un archivo fuera de la carpeta de fotos**; además aceptaba cualquier contenido como «imagen».	Se valida que la foto sea 1 a 4, que el contenido sea realmente JPG/PNG/WEBP (por sus primeros bytes) y se limpia el nombre del archivo. Pruebas con direcciones manipuladas.
4	**ALTA**	**Números de documento duplicados** cuando dos usuarios guardaban a la vez (CGI, vales, actas…). Reproducido en PostgreSQL: 12 operaciones simultáneas produjeron solo **4 números distintos**.	La numeración ahora incrementa de forma atómica (la fila queda bloqueada hasta confirmar). La misma prueba da 12 números distintos, en SQLite y en PostgreSQL.
5	Media	**Fechas por defecto en pantalla en horario UTC:** desde las 20:00 hasta medianoche (hora de Bolivia) los formularios proponían la fecha del día siguiente. También en el nombre de los respaldos y PDF.	Todas las fechas usan el calendario local del equipo.
6	Media	No había forma de **retirar los datos de demostración** ni los usuarios de prueba con clave conocida antes de empezar a trabajar con datos reales.	Nueva pestaña **Administración → Pasar a producción**: borra operaciones y usuarios de prueba, conserva configuración, administrador y catálogos (a elección), hace copia previa y exige escribir ELIMINAR. Con pruebas.
7	Media	El **token de sesión** que viaja en la dirección de los PDF/Excel (`?access_token=`) quedaba escrito en el registro del servidor.	El registro lo oculta (`access_token=***`). Verificado con el servidor en marcha.
8	Media	Faltaban **cabeceras de seguridad** y las respuestas de la API podían guardarse en la caché del navegador (riesgo en equipos compartidos).	Se agregaron `nosniff`, `X-Frame-Options`, `Referrer-Policy` y `Cache-Control: no-store` en la API.
9	Baja	Versión de escritorio: los enlaces externos se abrían con cualquier protocolo (por ejemplo `file:`).	Solo se permiten enlaces `http` y `https`; los PDF internos siguen abriendo.
10	Baja	La interfaz mostraba botones de edición de **catálogos compartidos** a roles que el servidor rechaza (error 403 al guardar). Una falla de pantalla dejaba la página en blanco. Un error no capturado podía detener el servicio.	Los botones coinciden con los permisos reales; nueva pantalla de aviso con «Volver al inicio»; el servidor registra el error y sigue funcionando.

3. Lo que se verificó y está bien

- **Consultas SQL:** todas usan parámetros; las pocas con texto armado usan nombres de columnas fijos del propio sistema (sin datos del usuario).
- **Permisos:** todas las operaciones que modifican datos exigen el rol del módulo o administrador (verificado ruta por ruta); los documentos y reportes exigen sesión.
- **Claves:** guardadas con scrypt y comparación de tiempo constante; mínimo 8 caracteres con letras y números; bloqueo tras 5 intentos; cambio obligatorio al primer ingreso.

- **Importaciones (Excel y VSIAF):** validan todas las filas antes de guardar, trabajan en una sola transacción y registran en la bitácora; el VSIAF se respalda y se restaura si falla.
- **PostgreSQL:** las 205 pruebas ejecutables pasan; las consultas nuevas (importaciones, numeración, producción) funcionan en ambos motores.
- **Interfaz web:** no usa `innerHTML` ni `eval`; el texto de los usuarios no puede inyectar código.

4. Riesgos pendientes y recomendaciones

4.1 Riesgos menores aceptados

Tema	Detalle	Recomendación
Vulnerabilidad moderada en `uuid` (dentro de `exceljs`)	Solo afecta a un uso del componente que SIGAA **no realiza**.	Actualizar `exceljs` cuando publique una versión corregida.
Bloqueo por intentos fallidos	Es por nombre de usuario y en memoria: alguien podría bloquear una cuenta a propósito y el conteo se reinicia al reiniciar el servicio.	Si el sistema se publica fuera de la red de la entidad, poner un proxy con límite de intentos por dirección.
Sesiones	Duran 10 horas y no se pueden cerrar desde el servidor una por una (el usuario desactivado sí cae al instante).	Desactive al usuario que deje la entidad.
Códigos correlativos simultáneos	Dos personas codificando activos del mismo ambiente en el mismo segundo pueden recibir un error de clave duplicada; la operación se revierte completa.	Repetir la operación. No hay duplicados silenciosos.
Fotos HEIC (iPhone)	No se aceptan.	Convertir a JPG o configurar la cámara en «Más compatible».
Sin HTTPS propio	SIGAA sirve HTTP.	En red, publicarlo detrás de un proxy con HTTPS; no exponer el puerto a internet.

4.2 Lo que todavía no está probado

- **Con datos y equipos reales:** el envío y la lectura del VSIAF se probaron con instalaciones de ejemplo; falta una prueba piloto con una **copia** del VSIAF real.
- **Instalador de Windows:** el archivo `CREAR_INSTALADOR_ESCRITORIO.bat` y la impresión de etiquetas en escritorio deben comprobarse en una PC con Windows (esta auditoría se hizo en Linux).
- **Carga:** no se hicieron pruebas con muchos usuarios simultáneos; para más de 20 usuarios simultáneos use PostgreSQL.

5. Conclusión y siguientes pasos

SIGAA queda **apto para una puesta en producción controlada**, siempre que se cumpla la *Lista de verificación para entrar en producción* del manual de implementación. Orden recomendado:

1. Instalar y actualizar con los archivos entregados; cambiar la clave del administrador.
2. Hacer una **prueba piloto de 2 a 4 semanas** con un caso real pequeño de cada módulo, usando una copia del VSIAF.
3. Pasar a producción (eliminar datos de demostración), cargar catálogos y logo.
4. Programar y **probar la restauración** de las copias de seguridad.
5. Repetir esta revisión de dependencias cada 3 a 6 meses.